Unit 1

Introduction to Data Privacy and Privacy Regulations: • Notion of data privacy, • Historical context of data privacy, • Types of sensitive data, • Privacy laws and regulations.	20	Ch-1 upto Sec 1.2 Ch-1 upto pg 8 Ch-2: 2.1 upto pg 33, Ch 3: 3.4, Ch 14: 14.1-14.4 Ref [5] complete	[3] [4] [2] [5]

Data Privacy = the right of people to control who sees their personal information.

Simple example: Your phone number, health records, or location should not be seen by anyone without your permission.

There are numerous such incidents where customers' confidential personal information has been attacked by or lost to a data snooper. When such untoward incidents occur, organizations face legal suits, financial loss, loss of image, and, importantly, the loss of their customers. Hence, data privacy is important.

Stakeholders in the organization:- **Company**, **Customer/record owner**, **Government**, **Data anonymizer**(a person who anonymizes and provides data for analysis or as test data), **Data analyst**(this person uses anonymized data to carry out data mining activities like prediction, knowledge discovery and so on), **Tester**, **Business operations employee**, **Adversary/data snooper**(anyone who tries to access, steal or misuse your personal data without permission).

4 types of data:-

i) Explicit identifiers (EI): Attributes that identify a customer (also called record owner) directly. These include attributes like social security number (SSN), insurance ID, and name.
ii) Quasi-identifiers (QI): Attributes that include geographic and demographic information, phone numbers, and e-mail IDs. Quasi- identifiers are also defined as those attributes that are publicly available, for example, a voters database.
iii) Sensitive data (SD): Attributes that contain confidential information about the record owner, such as health issues, financial status, and salary, which cannot be compromised at any cost.
iv) Nonsensitive data (NSD): Data that are not sensitive for the given context.

Privacy and Anonymity: Two Sides of the Same Coin

Anonymization = Data Masking + De-identification

Step 1: Data Masking

You hide or change the obvious identifiers so no one can directly see who the person is.

What you do in masking:

- Replace name → "Patient_001" or blank
- Replace Aadhaar/SSN/mobile → XXXXXX or random number
- Replace exact address/email → remove or fake it

After masking → Explicit Identifiers (EI) are gone or scrambled.

Step 2: De-identification

You now protect the **Quasi-Identifiers (QI)** so that even if someone tries to combine the remaining data with public records (voter list, social media, etc.), they still cannot figure out who the person is.

Common de-identification techniques:

- Generalization: 28 years → "25–30 years", Pincode 110001 → "Delhi"
- Suppression: Remove rare values (e.g., delete age if someone is 95)
- K-anonymity: Make sure at least 5 (or k) people look exactly the same on QI
- Adding noise (differential privacy)

After proper de-identification → even smart attackers cannot re-identify the person.

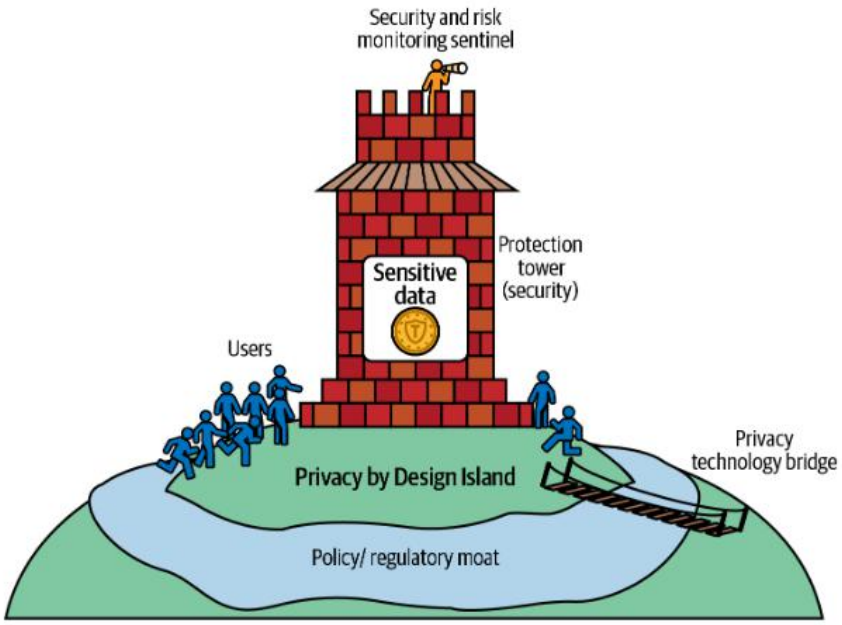


Figure 1-1. Mapping data governance

Data Governance: Overall system that makes sure organization handles data in a responsible, safe and legal way

Types of Sensitive Data:-

i) PII

Data that is unique or close to unique for a particular individual. This is usually defined in policy and regulations and can include things that you might not expect, such as your IP address, date of birth, and workplace.

ii) Person-related data

Data that relates to a person but doesn't fall under PII. This could be anything related to their personhood, including interests, beliefs, locations, and online and offline behaviors and activities.

iii) Proprietary and confidential data

Data deemed sensitive for contractual or business-related purposes. Its release would endanger a business or other legal relationship or agreement.

General Data Protection Regulation(GDPR)

1. **Who must follow GDPR?**
   Any company in the world (Google, Amazon, Indian startups, etc.) if they handle data of people living in the EU – even if the company is outside Europe.
2. **What is personal data now?**
   Much broader – name, email, IP address, location data, cookies, even online behavior is personal data.
3. **Consent rules are strict**
   No pre-ticked boxes, no confusing language. Users must clearly say "YES". You must keep proof of consent.
4. **Data Protection Officer (DPO)**
   Big companies and government offices must appoint a privacy expert (DPO) inside the company.
5. **Privacy Impact Assessment (DPIA)**
   Before starting any new project with personal data, you must do a risk check and fix privacy issues first.
6. **72-hour rule**
   If data is leaked/hacked → tell the government within 72 hours (3 days).
7. **Right to be Forgotten**
   User can say "delete all my data forever" and you have to do it (no keeping backups for marketing).
8. **Privacy by Design**
   Build privacy from day 1 when making apps/websites – not add later.
9. **Huge fines**
   Break rules → up to 4% of global turnover (example: ₹160 crore+ for big companies).
10. **Why everyone cares**
    GDPR is the world's strongest privacy law, so almost all countries and companies now copy its rules (including India's DPDP Act).

One-line summary:
GDPR is a 2018 EU law that forces every company worldwide to strictly protect EU people's data – with heavy fines if you don't. It is the main reason companies now ask for cookie consent and take privacy seriously!

For final exam(GDPR Full from book)

U.S. Privacy Laws

Privacy Act 1974: Federal government cannot misuse your personal data.

HIPAA 1996: Doctors & hospitals must keep your health records secret.

FERPA 1974: Schools cannot share student records without permission.

GLBA 1999: Banks must protect your financial information.

FACTA 2003: Credit companies must help prevent identity theft.

COPPA 1998: No website can collect data from kids under 13 without parents' OK.

CCPA 2020 (California): Companies must let you see, delete, and stop selling your data – USA's mini-GDPR.

India's DPDP(Digital Personal Data Protection) Act 2023

Applies to: All digital personal data in India + data of Indians processed abroad.
Core Rule: Process personal data only with clear, withdrawable consent OR for legitimate uses (govt, jobs, medical emergency).
Key Rights: Access, correct, erase, nominate (for kids), grievance redressal.
Duties of Companies:

- Consent + notice (clear, multi-language)
- Data minimization + purpose limit
- Security + breach reporting
- Delete when purpose over

Children (<18): Verifiable parental consent + no tracking/ads.
Significant Data Fiduciaries (big players): Must appoint DPO, do DPIA, audit.
Fines: Up to ₹250 crore per violation.
Government Exemptions: National security, legal enforcement.
Regulator: Data Protection Board of India (yet to be set up).
Transfers abroad: Freely allowed (no restrictions).

One-liner: India's simple, consent-first, high-fine privacy law – lighter than GDPR, stricter on kids, easy cross-border flow.

Unit 2

Data Privacy Attacks, Cryptography and Data Protection: • Type of Attacks/ Data Breaches on Data Privacy, • Impact of Data Breaches / Attacks, • Introduction to cryptography, • Symmetric and asymmetric encryption, • Hashing and digital signatures.	12	Ch-1 till Sec 1.11	[2]

Cybersecurity is the prevention of damage to, unauthorized use of, exploitation of, and—if needed—the restoration of electronic information and communications systems, electronic communications services, wire communication, and electronic communication, including information contained therein, to ensure its availability, integrity, authentication, confidentiality, and nonrepudiation

As subsets of cybersecurity, we can define the following:

- **Information security:** Preservation of confidentiality, integrity, and availability of information. In addition, other properties, such as authenticity, accountability, nonrepudiation, and reliability, can also be involved.
- **Network security:** Protection of networks and their services from unauthorized modification, destruction, or disclosure and provision of assurance that the networks perform their critical functions correctly, without harmful side effects.

Key security objectives:-

- **Confidentiality:** Also known as ***data confidentiality***, the property that information is not made available or disclosed to unauthorized individuals, entities, or processes. A loss of confidentiality is the unauthorized disclosure of information.
- **Integrity:** This term covers two related concepts:
  - **Data integrity:** Ensures that data (both stored and in transmitted packets) and programs are changed only in a specified and authorized manner. A loss of data integrity is the unauthorized modification or destruction of information.
  - **System integrity:** Ensures that a system performs its intended function in an unimpaired manner, free from deliberate or inadvertent unauthorized manipulation of the system.
- **Availability:** Ensures that systems work promptly and that service is not denied to authorized users. A loss of availability is the disruption of access to or use of information or an information system.

- **Authenticity:** The property of being genuine and being able to be verified and trusted; confidence in the validity of a transmission, a message, or a message originator. This means verifying that users are who they say they are and that each input arriving at the system came from a trusted source.

- **Accountability:** The security goal that generates the requirement for actions of an entity to be traced uniquely to that entity. This supports nonrepudiation, deterrence, fault isolation, intrusion detection and prevention, and after-action recovery and legal action. Because truly secure systems are not yet an achievable goal, it must be possible to trace a security breach to a responsible party. Systems must keep records of their activities to permit later forensic analysis to trace security breaches or to aid in transaction disputes.

10 Challenges of Information Security & Privacy – Ultra Short Version

1. Looks simple (confidentiality, integrity, etc.) → actually very complex.
2. Designers must always think like attackers to find hidden weaknesses.
3. Security solutions often feel "too complicated" until you see the real threat.
4. Deciding where to place security controls (network, app, VM, etc.) is hard.
5. Needs secret keys + reliable protocols; delays or bad design can break everything.
6. Attacker wins by finding 1 hole; defender must close 100% of holes.
7. No one wants to pay for security until a breach happens.
8. Security needs constant monitoring — most companies are too busy or short-staffed.
9. Privacy/security added at the end → always fails or costs 10× more.
10. Strong security feels annoying to users and admins → they try to bypass it.

Bottom line (1 sentence): Security & privacy are never easy or cheap — they are a never-ending cat-and-mouse game that must be built in from day one.

Ultra-Short & Exam-Ready Summary of 1.2 (X.800 OSI Security Architecture)

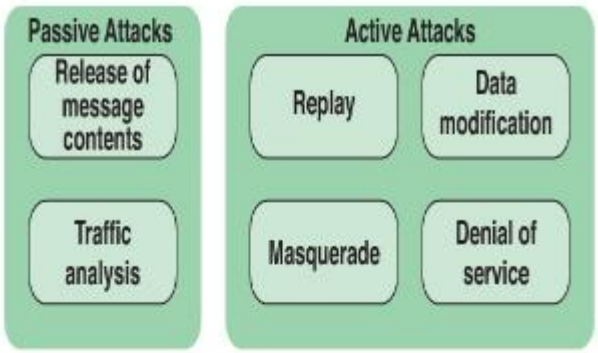
Term	Definition (1 line each)
Security Attack	Any action that breaks confidentiality, integrity, or availability of information.
Security Mechanism	Tool or process (encryption, firewall, IDS, etc.) to detect, prevent, or recover from attacks.
Security Service	The goal we want: Confidentiality, Integrity, Authentication, Non-repudiation, Access Control, Availability.
Threat	A possible danger that could happen (potential).
Attack	Actual malicious action happening right now (active).

Relationship (most asked in exams)

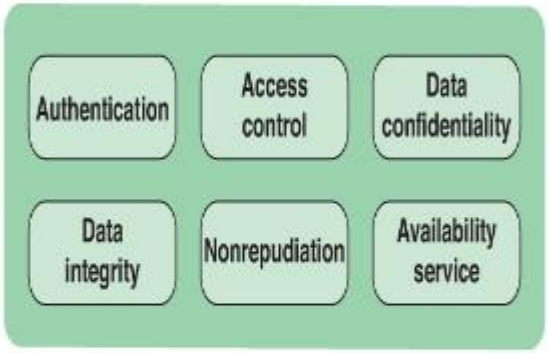
Security Services → achieved using → Security Mechanisms → to stop → Security Attacks → caused by → Threats.

One-liner to remember forever

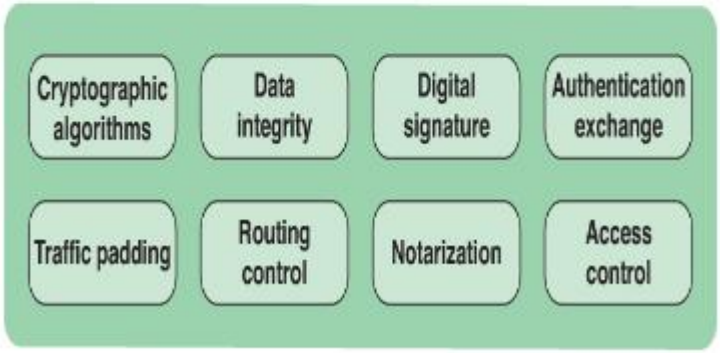
"Threat is the villain who might strike; Attack is the villain striking; Mechanism is the shield; Service is the protection we want."



(a) Attacks



(b) Services



(c) Mechanisms

FIGURE 1.2 Key Concepts in Security

Passive vs Active Attacks – Ultra Short & Exam-Ready

Type	What happens?	Examples	Detectable?	Preventable?	Focus
Passive	Only **listening/ observing** – no change to data	1. Release of message contents (read email/ phone call) 2. Traffic analysis (see who talks to whom, when, how much)	Very hard to detect	Easy with **encryption**	**Prevention** (use strong encryption)
Active	**Changes** data or system	1. **Masquerade** – pretend to be someone else 2. **Replay** – capture & resend valid data 3. **Modification** – alter message (e.g., "Pay ₹100" → "Pay ₹10,000") 4. **Denial of Service (DoS)** – block access/flood network	Easy to detect (something breaks)	Very hard to fully prevent	**Detection + Recovery**

One-Liner to Remember Forever

- **Passive** = Silent spy → **encrypt** to stop.
- **Active** = Violent attacker → detect fast & recover.

Exam favorite line:
"Passive attacks are difficult to detect but easy to prevent with encryption; active attacks are easy to detect but difficult to prevent completely."

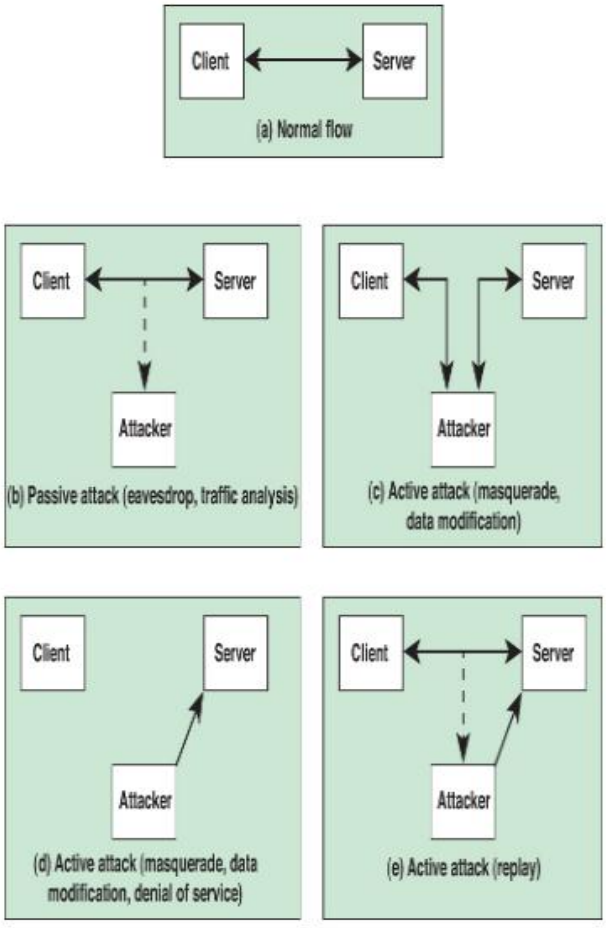


FIGURE 1.3 Security Attacks

1.3 Security Services – 6 Core Services (Ultra Short & Exam-Ready)

Service	One-Liner Meaning	Real-Life Example
Authentication	Prove "You are really YOU"	Login with password/OTP/biometric
Access Control	Only allowed people can enter/use something	Only HR can see salary files
Confidentiality	Nobody else can read the data	HTTPS, WhatsApp end-to-end encryption
Data Integrity	Data is not secretly changed	Hash/checksum, digital signature
Non-repudiation	You can't say "I didn't do/send it" after doing it	Digital signature on bank transaction
Availability	System works when you need it (no crash/DoS)	Website stays up even during attack

Quick Mnemonic (C-I-A + A-A-N)

Confidentiality **I**ntegrity **A**vailability **A**uthentication **A**ccess Control **N**on-repudiation

Exam Favorite Line

"Security services define WHAT we want to achieve; security mechanisms (encryption, firewall, etc.) are HOW we achieve them."

X.800 – Two Specific Authentication Services (Super Short)

Service	What it does	When used	Protects against	Example
Peer Entity Authentication	Verifies **"you are really you"** during the **live connection/session**	At login/handshake or during session	Masquerade & Replay attacks	HTTPS handshake, SSH login, OTP during banking session
Data Origin Authentication	Verifies **"this message really came from whom it claims"** (no live session needed)	One-way or delayed communication	Fake sender (but not replay/ modification)	Digital signature on email, signed PDF, JWT token

Quick Difference (Exam Gold)

- **Peer Entity** → Two-way, live session → "Are you real right now?"
- **Data Origin** → One-way, no session → "Did this really come from Alice?"

Remember:
Peer Entity = mutual & live
Data Origin = just checks the source, even later

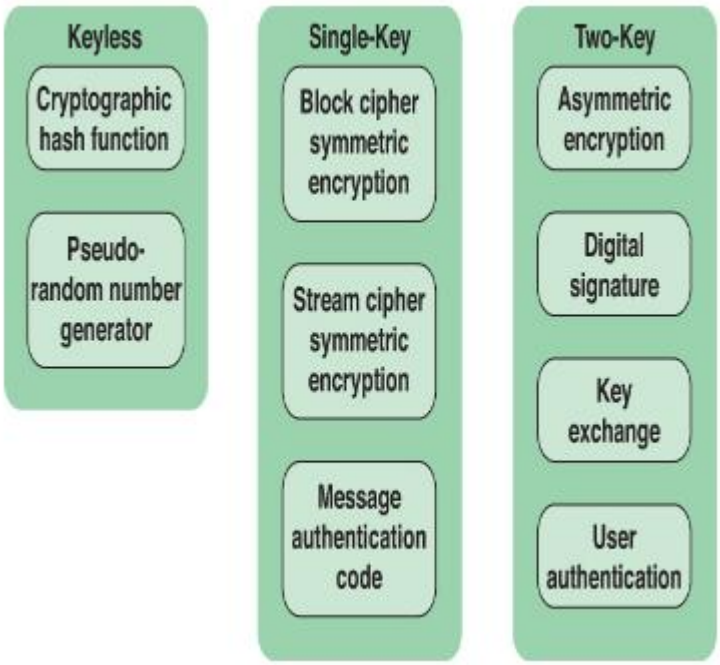
1.4 Security Mechanisms – X.800 List (Ultra Short & Exam-Ready)

Mechanism	One-Liner Purpose	Typical Example / Tool
Cryptographic algorithms	Make data unreadable to outsiders	AES, RSA, ChaCha20
Data integrity	Detect if data was changed	Hash (SHA-256), HMAC, checksum
Digital signature	Prove who sent it + data not altered	RSA/ECDSA signature, PDF signing
Authentication exchange	Mutual or one-way "prove your identity"	Challenge-response, Kerberos tickets, OTP
Traffic padding	Add fake data to hide real traffic patterns	Constant bitrate in VoIP/video
Routing control	Force data to go through safe/encrypted paths	VPN routing, Tor, route filtering
Notarization	Trusted third party guarantees properties	Timestamping service, e-notary
Access control	Only allowed people/resources can access something	RBAC, ACLs, firewall rules, file permissions

Exam Mantra

Services = WHAT we want

Mechanisms = HOW we achieve it



Cryptographic Algorithms:-

1. **Keyless Algorithms** These need no secret key at all. There are two main ones:
    1. **Cryptographic hash** (e.g., SHA-256): you put in any amount of data and get a small fixed-size "fingerprint" (hash). Same input → same hash; even a tiny change → completely different hash. Used to check if data was altered or to safely store passwords.
    2. **Pseudorandom generator**: looks random but is actually repeatable if you know the starting seed. Used to create keys or random-looking numbers inside crypto systems.

2. **Single-Key (Symmetric) Algorithms** Same secret key is used to lock and unlock the data. Both sender and receiver must have this same secret key. Very fast, perfect for encrypting huge files, disks, or live connections (WhatsApp, HTTPS, VPN). Famous examples: AES-256, ChaCha20. Problem: you must find a safe way to share the key first.
3. **Message Authentication Code – MAC (also single-key)** Uses the same shared secret key + the message to produce a short tag (like a digital seal). Receiver recalculates the tag with the same key; if it matches, the message is genuine and unchanged. Common examples: HMAC, Poly1305. Gives integrity + authenticity, but no encryption.
4. **Two-Key (Asymmetric / Public-Key) Algorithms** Everyone has two keys: a **public key** (share with the world) and a **private key** (keep totally secret).

    1. Anything encrypted with the **public key** can only be decrypted by the **private key**.
    2. Anything signed with the **private key** can be verified by the **public key**. Slower than symmetric, so mainly used for: → Digital signatures (prove "I really sent this") – ECDSA, RSA → Secure key exchange (send a symmetric key safely) – Diffie-Hellman, ECDH → Initial secure handshake in HTTPS/TLS.

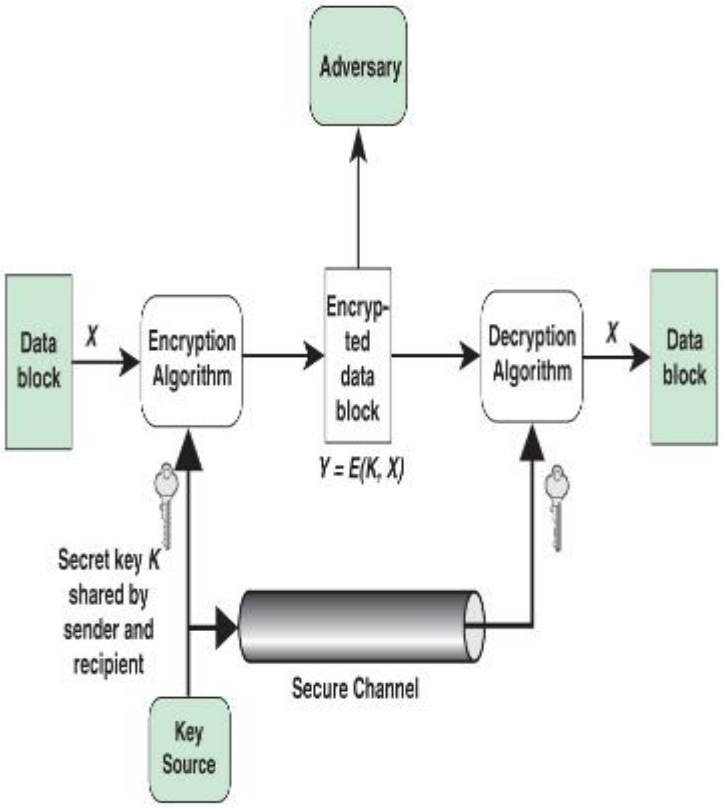


FIGURE 1.5 Model of Symmetric Cryptosystem

Two Ways to Attack Symmetric Encryption – Super Simple

An attacker has only **two basic ways** to break symmetric encryption:

1. **Cryptanalysis (Smart Attack)** The attacker studies the encryption algorithm itself, looks for weaknesses in how it works, and uses tricks/math to guess the secret key or the original message.
    1. May use known plaintext-ciphertext pairs
    2. Exploits flaws or patterns in the algorithm
    3. If successful → recovers the **key** → **total disaster**: all past and future messages using that key are readable forever.
2. **Brute-Force Attack (Dumb but Powerful)** The attacker simply tries **every possible key** one by one until the correct one is found.

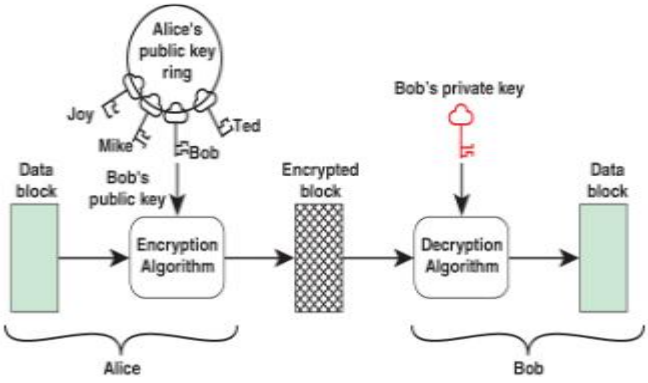
    1. No intelligence needed, just computer power
    2. With a 128-bit key → 2^{128} possibilities (impossible today)
    3. With a 256-bit key → 2^{256} (completely impossible even in 1000 years)
    4. On average, needs to try **half** the key space.

Bottom Line (Exam Gold)

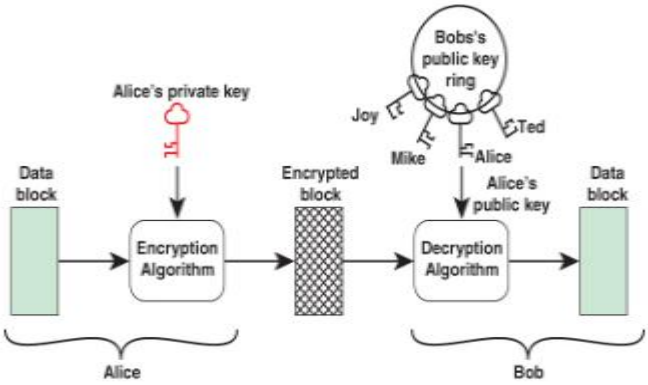
To be secure, a symmetric cipher must have:

> A **strong algorithm** that resists cryptanalysis (e.g., AES, ChaCha20)
> A **long enough key** (at least 128-bit, better 256-bit) to make brute-force impossible.

That’s why modern symmetric encryption (AES-256) is considered unbreakable today!



(a) Public-key encryption/decryption (Alice encrypts block for Bob only)



(b) Public-key encryption/decryption (Alice authenticates block for any recipient)

Cryptographic Hash – Ultra-Compact Version

What: Turns any data → fixed-size fingerprint (e.g., SHA-256 = 256 bits).

6 Magic Properties (must know):

1. Any size input
2. Fixed size output
3. Super fast
4. Preimage resistant (can't reverse)
5. 2nd preimage resistant (can't find different file with same hash)
6. Collision resistant (can't find ANY two files with same hash)

Real Uses:

- Password storage
- File integrity (ISO checksums)
- Digital signatures
- Blockchain / Git / Bitcoin

One-liner:
"One-way, fixed-length, unforgeable digital fingerprint."

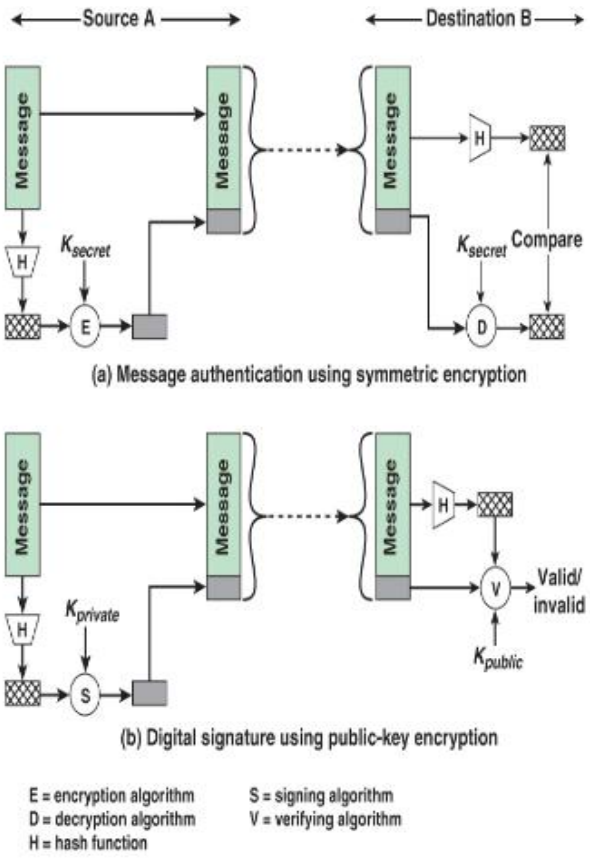


FIGURE 1.7 Uses for a Secure Hash Function

Message Authentication with Hash – Ultra-Compact

Method = HMAC (Hash-based Message Authentication Code)

How it works (4 steps):

1. Sender: Compute hash(message) → e.g., SHA-256
2. Sender: Encrypt that hash with **shared secret key** → "MAC"
3. Send: original message + MAC
4. Receiver: Re-compute hash(message) with same key → compare with received MAC

If MAC matches → 3 guarantees:

- Message **not altered** (integrity)
- Message really from **claimed sender** (authenticity)
- Proper **sequence** (if sequence number is inside)

Name of this construction: HMAC-SHA256, HMAC-SHA3, etc.
Used everywhere: TLS, JWT, API signing, SSH, IPsec.

One-liner:
"Hash + secret key = unforgeable proof that the right person sent the exact message."

Digital Signature – Ultra-Compact Summary

What it is

A short cryptographic proof that "I really sent/wrote this **exact** message and I **cannot deny** it later".

How it works (3 steps)

1. Sender: Hash(message) → tiny fingerprint
2. Sender: Sign the hash with **private key** → digital signature
3. Send: message + signature

Receiver checks

Hash(message again) → use sender's **public key** to verify signature
→ If match → 100% proof of:
• Origin (only private-key owner could sign)
• Integrity (message not changed)
• Non-repudiation (sender cannot say "I didn't sign it")

Real names you see daily

- RSA-PSS, ECDSA (most common), Ed25519 (fast & modern)

Used everywhere

Email (S/MIME, PGP), HTTPS certificates, software updates (Windows, Android, Linux), blockchain transactions, PDF signing, JWT tokens, etc.

One-liner

"Digital signature = sign the hash with private key → anyone can verify with public key → unbreakable proof of who + what + cannot deny."

1.10 Practical Crypto – Ultra-Compact Cheat Sheet (2024–2025)

What to use TODAY (official NIST/ENISA recommendation)

Purpose	Algorithm	Minimum Safe Size	Status 2025
Symmetric encryption	**AES**	128-bit (OK), **256-bit** best	Gold standard, use everywhere
Hash function	**SHA-2** or **SHA-3**	**256-bit minimum**	SHA-256 still perfect
Digital signatures	**ECDSA** or **Ed25519**	256-bit curve (P-256)	Fast & secure
	RSA (legacy only)	**3072–4096-bit**	Slow, being phased out
Key exchange	**ECDH** or **X25519**	256-bit curve	Standard in TLS 1.3

Implementation Rules (must follow)

- Never invent your own crypto → always use standard algorithms
- Prefer hardware acceleration (AES-NI, ARM Crypto Extensions) → 10× faster
- Key management is the hardest & most broken part (use proper vaults)
- Validate modules with **FIPS 140-2/3** if government/compliance needed

Future-Proof Sections

Topic	What it is	Current Winner / Status 2025
Lightweight Crypto	Tiny, low-power for IoT/ sensors	ASCON (2023 winner), still rolling out
Post-Quantum Crypto	Survives quantum computers	Kyber (ML-KEM) & Dilithium (ML-DSA) standardized Aug 2024 → start migrating now

One-Liner for Exams/Interviews

"2025 safe combo: AES-256 + SHA-256 + ECDSA/Ed25519 (or Dilithium for post-quantum) with proper key management."

PKI & Certificates – Explained Like You're 10 Years Old (but 100% accurate)

The Big Problem
On the Internet, anyone can say "Hi, I'm google.com, here is my public key."
How do you know it's really Google and not a hacker pretending to be Google?

The Real-World Analogy

- Your **public key** = your face
- Your **private key** = your DNA (only you have it)
- A **certificate** = your passport
- The **CA (Certification Authority)** = the government that issues passports

Just like you trust a passport because the government signed it, computers trust a certificate because a trusted CA signed it.

How a Certificate is Born (Step-by-Step)

1. You create your public + private key pair on your computer/server.
2. You prove to a CA (e.g., Let's Encrypt, DigiCert, Sectigo) that you really own the domain/name (usually by DNS or HTTP challenge).
3. The CA puts inside the certificate:
   - Your name/domain (google.com)
   - Your public key
   - Expiry date
   - CA's name
4. CA signs the whole thing with its own private key → certificate ready!
5. Now anyone who trusts that CA will automatically trust your public key.

Main Players in PKI

Name	Simple Meaning	Real Example
End Entity	Normal user or website that needs a certificate	google.com, your email, your phone
CA	Trusted "passport office" that issues & signs certificates	Let's Encrypt, DigiCert, GlobalSign
RA	Helper who checks your ID for the CA (optional)	Company HR verifying employees
Repository	Place where certificates & revocation lists are stored	Public websites, LDAP servers
Relying Party	Anyone who checks your certificate (your browser, phone, etc.)	Chrome, Safari, Outlook

How Your Browser Uses It Every Day (HTTPS)

1. You visit https://google.com
2. Google sends its certificate (signed by a trusted CA)
3. Your browser already has the CA's public key built-in (root certificates)
4. Browser verifies the signature → "Yes, this public key really belongs to google.com"
5. Secure TLS connection starts → padlock shows

Revocation (When a Key is Stolen)

If someone steals your private key → CA puts your certificate on a **CRL** (Certificate Revocation List) or uses **OCSP** to say "this certificate is cancelled".
Browsers check this list → instantly stop trusting that site.

Trust Hierarchy (Why Browsers Trust Hundreds of CAs)

- One big **Root CA** (super trusted, key stored offline in vaults)
- Root signs **Intermediate CAs**
- Intermediate CAs sign millions of normal certificates
  → Your browser trusts ~150 root certificates pre-installed (Microsoft, Apple, Mozilla, Google decide which ones).

One-Liner Summary

PKI = the global "passport system" for the Internet that lets every device prove who it really is using certificates signed by a few hundred trusted CAs.

Unit 3

Data Collection, Use and Reuse: • Harms Associated with Data collections, use and reuse, • Introduction to data anonymization, • Data Anonymization Techniques for anonymizing data, • Challenges in anonymizing data	8	Ch-3: Sec II Ch-1: Section 1.4-1.7	[1] [3]

II. Harms from Loss of Privacy – Super Short & Clear Notes

(Perfect for exam + interview answers)

Evolution of "Privacy Harms" Over Time

Era	Main Fear / Harm	Who/What Caused It	Famous Thinker / Event
Ancient Greece	State interfering in family life	Government	Aristotle (household vs state)
1800s	Society judging private choices	Law / public opinion	John Stuart Mill (individual liberty)
1890	Paparazzi, gossip press, hidden cameras	New technology + media	Brandeis & Warren article (1890)
1960s	Fake ads using your photo, identity fraud	Commercial misuse	William Prosser (US law review)
2000s–today	Identity theft, data breaches, AI discrimination	Big Tech + hackers	Facebook-Cambridge Analytica, Equifax leak

Modern Harms from Loss of Digital Privacy (2025 list)

Harm	Real-Life Example
Identity theft	Someone takes loan in your name
Financial loss	Stolen credit-card / bank details
Embarrassment / blackmail	Health, sexual, political data leaked
Discrimination	Insurance/job denied because of predicted disease or caste
Price discrimination	Same Uber ride costs ₹400 for iPhone user, ₹250 for Android
Manipulation	Targeted political ads (Cambridge Analytica style)
Chilling effect	You stop Googling sensitive topics because you feel watched
Loss of autonomy	Companies/govt know you better than you know yourself

Public Attitude (Survey Findings – US, UK, India same)

- People ARE worried about privacy
- BUT they still want convenience (fast delivery, free apps, better healthcare)
- They accept some risk IF they get clear personal benefit
- They are OK sharing data for public good (medical research, crime prevention)
  → Bottom line: "I'll share data only if I trust you and I get something useful."

Harms from Loss of Privacy – Part II

"The Privacy Paradox" Explained in 2 Minutes (Exam-Ready)

What People Say In Surveys	What People Actually Do	This is called...
"I'm very worried about my privacy"	Keep using Facebook, Google, loyalty cards	**Privacy Paradox**
"I hate targeted ads"	Accept cookies for 10% discount	
"Companies should not track me"	Click "Accept All" in 2 seconds	
"I don't want my data sold"	Still shop at BigBasket/Amazon for convenience	

Why the Paradox is NOT Stupid – It's Actually Rational

Real Reason (Research Findings)	Simple Explanation
People want benefits (discounts, convenience, free apps)	"I know it's risky, but I still save ₹500/month"
People feel the deal is unfair	"Companies get billions, I get ₹50 voucher – bad bargain!"
People don't understand what really happens	Think "anonymised = safe" → but companies still guess pregnancy, disease, caste, etc.
Zero real choice	If you say NO to cookies → website breaks or charges money
Distrust everywhere	"Nobody explains how I actually benefit" (exact quote from surveys)

Top 5 Harms People Fear Most (Survey Ranking)

1. **Identity theft / fraud** (stolen Aadhaar, card)
2. **Data breach / leak**
3. **Creepy targeted ads / manipulation**
4. **Discrimination** (higher insurance, no job)
5. **Loss of control** ("I don't know who has my data")

Best Exam One-Liner

"The privacy paradox is not hypocrisy – it's rational resignation in a system where people feel forced to accept a bad, opaque deal just to participate in modern life."

B. Insecure vs Imprecise Use of Data – Ultra-Clear 2-Minute Notes

Type of Harm	What it means (simple)	Real-Life Examples (2025)	Current Laws Help?
Insecure Use	Someone uses your data **illegally or without permission**	• Data breach → Aadhaar leak → fake loans • Company sells your data without consent	Yes (GDPR, DPDP Act, CCPA directly punish this)
Imprecise Use	Data is used **legally**, but the algorithm is **bad/ inaccurate** → still harms you	• Bank rejects loan because AI wrongly thinks you're risky • Health app says your mole is safe → actually cancer • Amazon shows you ₹10,000 more for same flight because you use iPhone • Facebook feed makes you more extreme, not better informed	Almost NO protection today (it's legal!)

Why Imprecise Use is the NEW Big Threat

1. People want personalised services (surveys prove it)
2. But the algorithms are often rubbish → harm instead of benefit
3. You can't check accuracy before saying "yes"
4. Even if purpose is good (fraud detection, better ads, medical diagnosis), **bad execution = discrimination or danger**
5. As AI gets used everywhere, **precise = safe, imprecise = new silent discrimination**

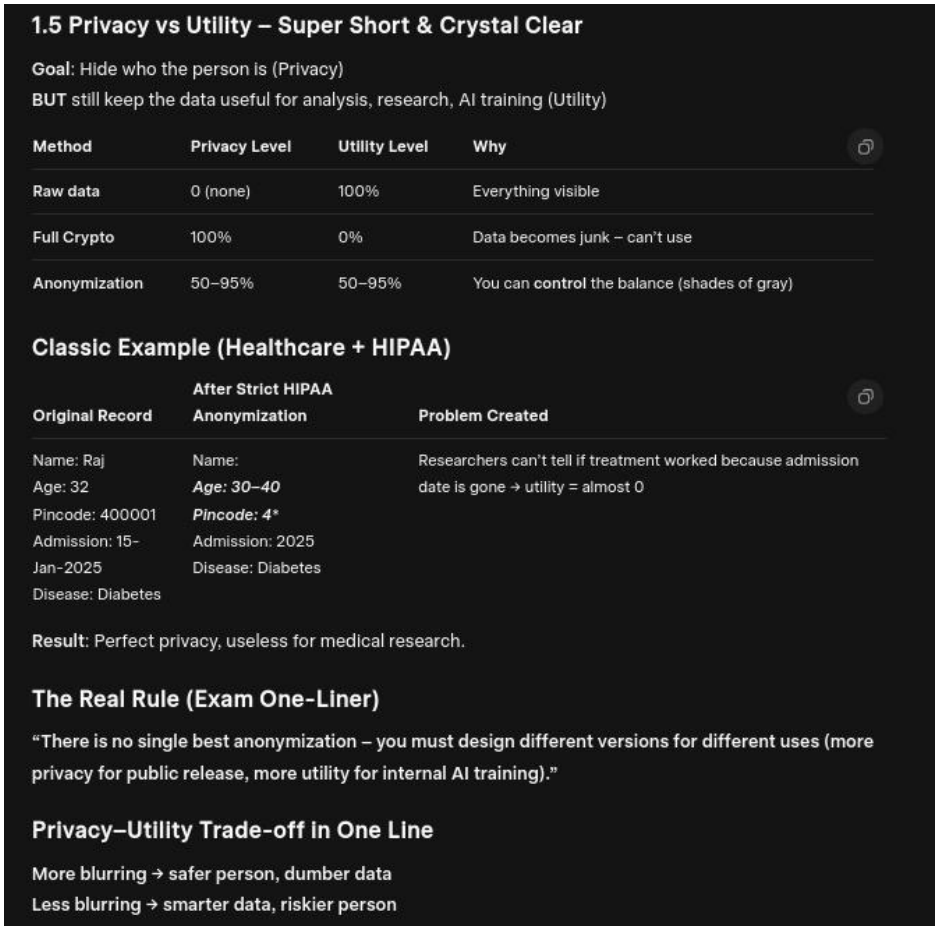
Exam Gold One-Liner

"Old privacy harm = data stolen (insecure use). New 2025 privacy harm = data used legally but badly (imprecise use) — laws still blind to this."

What We Are Trying to Protect

Sensitive / Personal Info = Anything that can identify you or reveal private things about you: Name, Aadhaar, PAN, phone, email, card number, health records, salary, location, religion, purchases, browsing history, etc.

Method	Simple Explanation (using one message)	Main Weakness	Example with a Message
Crypto	Locks the message with a secret key → becomes unreadable junk	Lose key = message lost forever	"Meet at 7" → x9$kL2m → only key turns it back
Hash	Turns message into a fixed fingerprint → impossible to reverse	Can't ever get message back	"Meet at 7" → a1b2c3d4e5 (one-way code)
Anonymize	Blurs the message so no one knows who sent it	Some details become less accurate	"Meet at 7, Raj, Mumbai" → "Meet at 7, Male, Maharashtra"
Tokenize	Replaces real message with a fake one that looks the same	Needs a secure vault to swap back	"Meet at 7" → Token#98765 (looks like normal text, vault knows real one)



1.5 Privacy vs Utility – Super Short & Crystal Clear

Goal: Hide who the person is (Privacy)
BUT still keep the data useful for analysis, research, AI training (Utility)

Method	Privacy Level	Utility Level	Why
Raw data	0 (none)	100%	Everything visible
Full Crypto	100%	0%	Data becomes junk – can't use
Anonymization	50–95%	50–95%	You can **control** the balance (shades of gray)

Classic Example (Healthcare + HIPAA)

Original Record	After Strict HIPAA Anonymization	Problem Created
Name: Raj Age: 32 Pincode: 400001 Admission: 15-Jan-2025 Disease: Diabetes	Name: ***Age: 30–40*** ***Pincode: 4**** Admission: 2025 Disease: Diabetes	Researchers can't tell if treatment worked because admission date is gone → utility = almost 0

Result: Perfect privacy, useless for medical research.

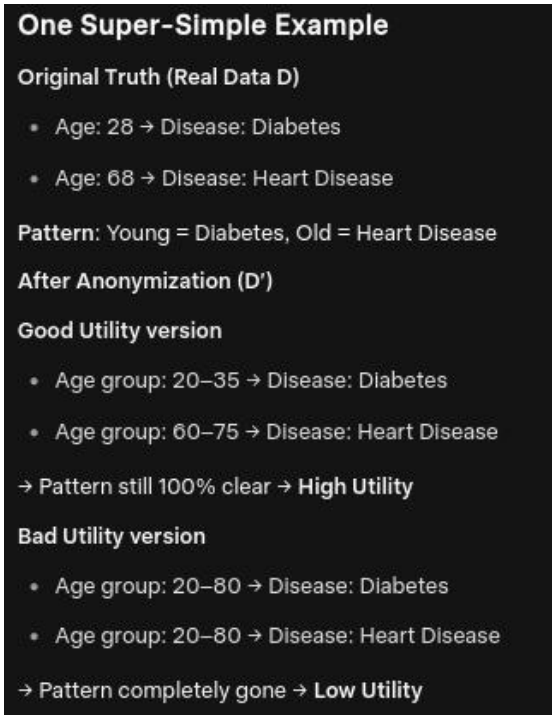
The Real Rule (Exam One-Liner)

"There is no single best anonymization – you must design different versions for different uses (more privacy for public release, more utility for internal AI training)."

Privacy–Utility Trade-off in One Line

More blurring → safer person, dumber data
Less blurring → smarter data, riskier person

Measuring Utility(High/Low): "Can you still see the same real-world patterns after anonymization?"



One Super-Simple Example

Original Truth (Real Data D)

- Age: 28 → Disease: Diabetes
- Age: 68 → Disease: Heart Disease

Pattern: Young = Diabetes, Old = Heart Disease

After Anonymization (D')

Good Utility version

- Age group: 20–35 → Disease: Diabetes
- Age group: 60–75 → Disease: Heart Disease

→ Pattern still 100% clear → **High Utility**

Bad Utility version

- Age group: 20–80 → Disease: Diabetes
- Age group: 20–80 → Disease: Heart Disease

→ Pattern completely gone → **Low Utility**

1.6 Anonymization Design Principles

Why it's hard: Most companies just buy a tool and click "Anonymize". Result → Either data becomes **too safe but useless** OR **still risky**.

Goal: Build anonymization that is **just right** for each use-case (not too much, not too little).

Figure 1.6 – Drivers for Anonymization Design (Super Easy Table)

Driver	Simple Meaning (in plain English)	Example Question to Ask Yourself
Business domain	What industry is this? (Healthcare, banking, retail, etc.)	"Is this hospital data or supermarket data?"
Data semantics	What do the columns actually mean?	"Does 'code 401' mean Diabetes or just a medicine?"
Regulations	Which laws apply? (HIPAA, GDPR, DPDP Act, Swiss law, etc.)	"Does law say remove admission date?"
Application	Who will use the data and for what? (research, testing, AI training, public release)	"Is this for internal AI or public download?"
Privacy requirement	How secret does it need to be? (low/medium/high risk)	"Can a hacker re-identify with this?"
Utility requirement	How accurate does the data need to stay?	"Do we still need to see age–disease pattern?"
Data type & structure	Is it normal table, graph, time-series, transactions?	"Is this simple rows or Facebook friend network?"
Environment	Where will the data live? (internal server, cloud, public website)	"Will it sit inside company or go to outsiders?"

One-Liner for Exam

"There is no single anonymization design – you must look at all 8 circles in Figure 1.6 and adjust blurring for each situation."

1.7 Nature of Data in the Enterprise – Final Ultra-Compact Table

(with k-anonymity definition)

What is k-anonymity?

→ At least k people (e.g., k=5) look **exactly the same** on quasi-identifiers (age, city, gender, etc.) so no one can pick you out.

Section	Data Type	Normal Example	Why Regular k-anonymity FAILS	Main Privacy Risk
1.7.1	**Multidimensional**	Customer table (Name, Age, City, Salary)	k-anonymity works fine here	Linking Age + City → identify person
1.7.2	**Transaction Data**	Supermarket receipt (Milk, Bread, Glucose meter)	Too many items + very sparse → one rare item breaks k-anonymity	Rare item (e.g., diabetes medicine)
1.7.3	**Longitudinal Data**	Same patient's BP every month for 2 years	All rows belong to one person + time order → k-anonymity on single rows is useless	Pattern over time identifies person
1.7.4	**Graph Data**	Facebook friend network	Your number of friends + friend-circle is unique → k-anonymity on nodes doesn't help	Degree & neighborhood attack
1.7.5	**Time-Series Data**	Daily stock price or weekly BP	Long sequence has unique shape/ trend → k-anonymity on single points destroys the shape	Shape/trend gives away identity

Unit 4

Ethical considerations in Data Privacy: • Privacy and Surveillance, • Ethics of Data Collection and Use, • Bias and discrimination in data analysis	5	Ch-3: Sec III, IV	[1]

Sections III & IV – Ultra-Compact & Exam-Ready Notes

(Everything in 1 page – perfect for last-minute revision)

Section	Topic	One-Line Summary + Key Points to Remember
III	How Does Data Protection Fight Insecure & Imprecise Use?	Data protection laws were built for **insecure use** (breaches, theft). They are still catching up with **imprecise use** (bad AI decisions).
A	The GDPR (2018)	World's strongest law. Covers both: • Insecure use → fines up to 4% global turnover for leaks • Imprecise use → Art. 22 bans purely automated decisions with legal effect unless consent/explicit law → Must give "meaningful information about the logic" (Art.13-15) and right to human review
B	Transparency, Consent & Fair Processing	• Consent must be freely given, specific, informed, unambiguous • "Notice & choice" is mostly broken (privacy paradox) • Transparency alone is not enough if the algorithm is still rubbish or biased
C	Privacy vs Consumer Protection	• Privacy law protects "personal data" • Consumer law protects against unfair prices, discrimination, bad products • When AI wrongly denies loan or shows higher price → it's both privacy harm AND consumer harm • Many countries now say: use consumer protection law to fight imprecise AI too
IV	Measuring Benefits vs Risks of Surveillance / Automated Decisions	We want to know: Is the AI system actually helping society or harming?
A	Model Surveillance System	Typical flow: Collect data → Train model → Predict (fraud, disease, crime, price, loan risk) → Act
B	Estimating Net Benefit	Net Benefit = (True positives × Benefit) − (False positives × Harm) − (False negatives × Missed benefit) Example: Fraud detection • Catch 100 real frauds → save ₹10 crore (good) • But wrongly block 10,000 genuine users → lose trust + ₹2 crore (bad)
C	Risks of Surveillance Systems Resulting in Net Harm	Common ways AI surveillance can have **negative** net benefit: 1. High false positives → mass discrimination 2. Feedback loop (predictive policing → more police in poor areas → more arrests → looks "correct") 3. Chilling effects (people stop free speech) 4. Hidden bias (Amazon hiring AI rejected women) 5. No transparency → impossible to audit

Exam Gold One-Liners

- "GDPR fights insecure use with huge fines and imprecise use with Article 22 + transparency rights."
- "Privacy paradox + bad consent → transparency alone cannot fix imprecise AI harms."
- "When AI makes mistakes, the harm is often a consumer protection problem, not just privacy."
- "Net benefit of surveillance = real gains minus false-positive pain; many systems today have negative net benefit."